



File No.: EXP202207910

RESOLUTION FOR FILING OF PROCEEDINGS

From the proceedings carried out by the Spanish Agency for Data Protection and based on the following:

FACTS

FIRST: The Spanish Agency for Data Protection became aware through a complaint of certain facts that could violate the legislation on data protection.

On July 19, 2022, the Director of the Spanish Agency for Data Protection urged the General Subdirectorate for Data Inspection (SGID) to initiate the preliminary investigation proceedings referred to in Article 67 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the Guarantee of Digital Rights (hereinafter, LOPDGDD) to investigate the CONSORTIUM BARCELONA SUPERCOMPUTING CENTER - NATIONAL SUPERCOMPUTING CENTER, CLINICAL HOSPITAL OF BARCELONA (HCB), FOUNDATION INSTITUTE OF HEALTH RESEARCH ILLES BALEARS, PUBLIC FOUNDATION OF ANDALUSIA FOR THE MANAGEMENT OF HEALTH RESEARCH IN SEVILLE, and UNIVERSITY HOSPITAL DOCE DE OCTUBRE, in relation to the following facts:

The Barcelona Supercomputing Center Consortium (hereinafter BSC-CNS) has access to personal data for which the hospitals 12 de octubre de Madrid, Clinic, Virgen del Rocío, and Son Espases would be responsible for processing. The accessed data would include: ID number, phone numbers, professional registration number, complete structured and unstructured medical history; there appears to be no adequate access control to such data, allowing any employee (including interns) to access and download it.

SECOND: The General Subdirectorate for Data Inspection proceeded to carry out preliminary investigation proceedings to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VII, Chapter I, Section two, of the LOPDGDD, being aware of the following aspects:

During the investigation proceedings, the following information requests have been made:

Requests to

BSC-CNS

:

In the responses received, the following is indicated:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

BSC-CNS is a public law entity integrated by the General State Administration, by the Administration of the Generalitat de Catalunya, and by the Universitat Politècnica de Catalunya, created through a collaboration agreement dated March 9, 2015, for the management and promotion of scientific, technical, economic, and administrative collaboration among the institutions that comprise it for the equipment and management of the BSC-CNS, the Spanish center for supercomputing and R&D&I; and execution agent of the Spanish System of Science, Technology, and Innovation (in accordance with the provisions of Article 3.4 of Law 14/2011, of June 1, on Science, Technology, and Innovation) whose infrastructures are part of the national map of Singular Scientific and Technical Infrastructures (ICTS).

Thus, this entity does not have the statutory purpose of processing data or information at public or entity levels in general, but rather involves complex supercomputing processes aimed, in most cases, at creating patterns or behavioral schemes not referring to specific subjects but to collectives. This implies that personal data is not necessary for the supercomputing analyses carried out in the scientific

projects or research of this entity.

(...)

Regarding the information requested concerning the processing of data from the Hospitals 12 de octubre de Madrid, Clinic de Barcelona, Hospital Virgen del Rocío, and Son Espases, it is necessary to indicate that the relationship linking BSC-CNS with these entities (with the exception of Hospital Virgen del Rocío, which is the Public Foundation of Andalusia for the Management of Health Research in Seville, located at the headquarters of that hospital) is duly regulated in the agreements signed by both parties and which are attached to this response as supporting documents.

The collaboration agreements referred to by the complainant are indeed attached to the response to the information request. On the other hand, two of the mentioned agreements are published in the BOE:

***URL.1

***URL.2

In all agreements signed by BSC-CNS with the various hospitals/foundations listed as being investigated in these proceedings, BSC-CNS is considered the Data Processor, while the Hospitals/foundations are considered the Data Controllers.

It continues to state that:

As can be inferred from the agreements attached to this response, the data was received anonymized; in some cases, the anonymization process was carried out directly by the Data Controller, as in the case signed with Hospital Son Espases, while in the other referenced agreements (Hospital 12 de octubre, Hospital Clinic, and Hospital Virgen del Rocío),

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/23

in which anonymized data was also received, but there was the possibility that in some cases it could be received in a pseudo-anonymized form and this was carried out by the data controller, in the event that it was necessary for the execution of the project.

In all agreements, it is clearly specified that BSC-CNS will receive anonymized or pseudonymized data:

Agreement with HCB

ANNEX 1

Contract for the processing of personal data.

Clause 1.3: BSC-CNS will receive anonymized data from HCB.

In this context, the regulations regarding the protection of personal data will not apply since personal data is not identifiable. However, for cases where BSC-CNS receives pseudonymized data from HCB, this processing assignment is formalized to regulate the rights and obligations of the Parties concerning the applicable data protection regulations.

Agreement with IdIsBa

Clause 5: It is the responsibility of IdIsBa to make available to BSC-CNS the anonymized discharge medical reports of patients admitted to Neurology, in accordance with the requirements for their analysis.

Agreement with FISEVI

ANNEX 1

Agreement for the processing of personal data

Clause 1.4: Without prejudice to what is described in section 1.3, BSC-CNS will receive anonymized data from FISEVI from the outset. In this context, the regulations regarding the protection of personal data will not apply since personal data is not identifiable as established in this Agreement. However, for cases where BSC-CNS receives pseudonymized data from the outset from FISEVI, this processing assignment is formalized to regulate the rights and obligations of the Parties concerning the applicable data protection regulations.

Agreement with H12O

First Clause. Purpose of the collaboration.

1.1 The purpose of this Agreement is to establish a framework for scientific and technical collaboration between BSC-CNS and H12O in order to provide an immediate response to the health crisis and emergency being experienced in Spain as a result of the COVID-19 pandemic.

1.2 To this end, within the framework of this collaboration as advanced in the administrative background, the Parties agree that H12O will transfer to BSC-CNS the pseudonymized data outlined in Annex 1 of this Agreement for the purpose of enabling BSC-CNS to carry out:

1. Automatic analyses of the content of clinical texts through systems of automatic extraction and normalization of clinical concepts;

2. Recognition of clinical entities relevant to COVID-19 and generation of annotated and structured data aimed at the development and quality evaluation of systems based on automatic information extraction.

1.3 In this regard, the transfer of pseudonymized personal data from H12O to BSC-CNS will be carried out exclusively and strictly for the purposes of this Agreement. For this, the Parties will sign the agreement for the processing of personal data attached in Annex 1.

1.4 The specific actions of joint cooperation between the Parties are defined in Annex 2 of this Agreement within their respective areas of competence.

BSC-CNS continues to state that:

"In all these cases, the data processed in the projects has been anonymized since it was not necessary to have personal data for the analyses and supercomputing tasks commissioned. This data was always received in such a way that it did not allow for the identification of the data subject, as it was not necessary to process the data, according to the principle of minimal intervention in data processing."

Despite this, and with the aim of complying with data protection regulations, the following record of activities was collected preventively as a possible data processing – in the capacity of data processor by BSC-CNS – for those projects:

A Record of Activities (RAT) of PROJECTS is attached in the capacity of Data Processor with the following description: Management of projects where it participates as a data processor providing some service via contract or executing scientific and/or research tasks under agreements or collaboration agreements.

The RAT also contains the following fields: Treatment system; Data source; Purposes; Categories of data subjects; Categories of data; Categories of recipients; and Security measures.

Regarding security measures, BSC-CNS states that:

"(...), in which only the members of the unit participating in the respective project had access. This system ensures security by groups, following the highest security standards. BSC-CNS contracted this system with the provider IBM, who is the developer of this tool and guarantees its maintenance. Furthermore, it is highlighted that one of the characteristics of this system is to have separate secure file spaces, which allow other users of the tool not to access data from other groups unless they are expressly authorized."

In the second request sent to BSC-CNS, information related to security measures is requested.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/23

Additionally, various sampling documentation was requested to verify compliance with the GDPR requirements and the agreements. For example, in the Agreement signed with the Son Espases University Hospital and the Health Research Institute Foundation of the Balearic Islands, it is established in clause six, last paragraph, the obligation to destroy the original dataset in any case before March 31, 2021. BSC-CNS was requested to provide proof of the destruction of said data, which was attached as document 10 of the BSC-CNS response 2.

Document 4 has been provided as the "Independent Report on Compliance with Security Measures regarding the files or processing of personal data carried out by BSC-CNS."

Document 6, the "Risk Analysis," has also been submitted.

As stated by BSC-CNS, the following policy of action was followed:

1) Description of the working means provided to employees.

BSC-CNS provides technical means (computer, monitor, keyboard, mouse) to its employees, access to the supercomputers as necessary, and other material means such as mobile devices when required. To do this, the direct supervisor of that employee must fill out a request/form that must be approved by the Operations Department and Administration. In exceptional cases and duly justified, the use of personal means has been authorized at the request of the user. This exceptional situation specifically affects an employee who had access to anonymized data in the agreements and who was allowed to use his own personal computer due to the exceptional situation of the pandemic. This employee worked remotely from the Basque Country, and the Head of the Data Mining Unit authorized him to use his own personal computer, at the prior request of that employee, who was informed of the BSC-CNS security rules for remote work. (...)

2) Document of the Information Security Policy and any other approved security document or procedure related to the signed agreements.

The employees of the Data Mining Unit were aware that they were dealing with anonymized clinical texts and that they were regulated by agreements. In this context, the employees who accessed that data did so with the corresponding security measures. The clinical texts were treated rigorously regarding their protection; a distinction was made between "health data," which is generic health information not related to a natural person (field articles, downloads from domain websites, patents), and "anonymized medical records." The former were used for annotating and training models and were published openly to share them with the scientific community in order to research and find solutions to the health crisis; while the latter (even when anonymized) were never published or shared with third parties. The employees who accessed that anonymized data were aware of the rules and limits of observance regarding the data. Thus, in the weekly group meetings, the data policy was reiterated, and questions were resolved. Everyone was informed that if any personal data was detected or there was suspicion of re-identification, they had to report it immediately to the Head of the Data Mining Unit. The Data Mining group was small enough (7 people) to ensure that the information was known by all and that they had to comply with the relevant security and confidentiality measures established in the User and Security Policy. Document number 1 is attached.

Furthermore, it should be noted that all users were aware of the obligations and duties of employees regarding data handling and security measures. Document number 2, "Decalogue of the Ten Basic Points," is attached, which outlines the functions and obligations of the users.

The staff with access to the anonymized information were aware that the anonymization was carried out at source by the hospital entities, that BSC-CNS did not participate in the process or in the anonymization techniques, and that BSC-CNS staff had to respect the control measures regarding access to the anonymized information. They were also informed that in the event of a breach of the re-identification chain, they had to notify the Head of Data Mining so that he could reliably communicate this fact to the Hospitals.

(...).

In the last information request, BSC-CNS was asked for the following information:

1.- Declaration of compliance with the obligations detailed in the BSC-CNS User Responsibilities Policy, before accessing the information hosted on the servers, signed by all users listed on page 6 of their response to the AEPD information request, dated 01/26/2023 and entry record REGAGE23e00005485531, and in document number 3, email of the list of users who had authorized access by the HCB.

In compliance with this request, the required documentation is provided as document 1. The Policy of Responsibilities of the complainant as a user of BSC-CNS is not signed, although it should have been accepted to access the resources of BSC-CNS.

Additionally, since at least two of the agreements were public, as they were published in the BOE, it is not possible to assert that the staff serving BSC-CNS was unaware of the duty of confidentiality, as this obligation is stated in both cases:

C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es
7/23

HCB Agreement:

Clause Six. Confidentiality.

6.1 The Parties commit to keeping confidential the terms and conditions of this Agreement, as well as the information of the other Party to which they gain access as a result of it, ensuring that they will not disclose any data they come to know through the contractual relationship established, except when they have express written authorization from the other Party. The obligation of confidentiality is exempted when, by legal provision or at the request of a judicial or administrative authority, one Party must disclose the confidential information of the other.

For this purpose, and in order to comply with Law 19/2014 on transparency, access to public information, and good governance, information related to collaboration agreements will be published as provided in Article 14 of the aforementioned law.

6.2 Any information, regardless of its nature, that may be provided between the Parties in relation to the object of this Agreement, will be considered as "Confidential Information" and will be treated confidentially by the Receiving Party, its employees, and collaborators, and will not be disclosed, in whole or in part, without the prior written consent of the Disclosing Party. (...)

ANNEX 1

Contract for the processing of personal data

CLAUSES

1. Object

1.1 The Data Processor shall keep secret the personal data of which it becomes aware as a result of this collaboration. All personnel of the Data Processor entity who access and/or process personal data are subject to professional secrecy and the duty of confidentiality, an obligation that continues once the relationship between the Parties has ended.

H12O Agreement:

Eighth. Confidentiality.

8.1 The Confidential Information will be treated confidentially by the Receiving Party, its employees, and collaborators, and will not be disclosed, in whole or in part, without the prior written consent of the Disclosing Party.

Additionally, with the third request for information, documentation provided by the complainant was attached. Specifically, the 5 pages containing personal data that are not anonymized, and for this purpose, the complainant's login was obfuscated. Justification for these circumstances and the reasons that led to this situation were requested, with BSC-CNS stating the following:

In order to respond to this section, we consider it necessary to contextualize this data processing; especially those related to Hospital 12 de Octubre and Hospital Clínic de Barcelona, given that the information attached to the complaint refers to these hospitals. These agreements were signed during the COVID pandemic and aimed to provide an immediate response to the health emergency that was being experienced in Spain at that time. The scientific and technical collaboration with these hospitals aimed to facilitate the automatic processing of clinical documents related to COVID-19 patients, in order to create structured data models to improve the analysis, management, treatment, and prediction of outcomes and evolution during the care process and hospital admission of these patients. Thus, the goal was to have information about the characteristics of this disease in order to create a predictive model, curb the disease, and consequently the infections. Therefore, for BSC-CNS, it was neither relevant nor of interest to obtain identifying data of the patients as there was no treatment of patients. For this reason, and in accordance with data protection regulations and the principle of minimal intervention, BSC-CNS received anonymized clinical texts to which BSC-CNS applied natural language processing techniques to enable the automatic extraction and normalization of clinical concepts. No personal data was required to carry out this process.

In both agreements, BSC-CNS aimed to: a) carry out data mining activities and b) develop predictive models, and the hospital entities were obliged to send anonymized data at source to BSC-CNS. The

objective of BSC-CNS was to receive anonymized data at source since identifying or processing personal data was not necessary to perform the tasks of the agreement. The obligations and methodology of work employed by BSC-CNS within the framework of these agreements are described below:

a) Data mining activities

The data mining activities aimed to facilitate the extraction of information from anonymized clinical histories of COVID-19 patients relevant for the development of predictive models. Text mining is the process by which relevant information is extracted from texts and allows converting explicit unstructured information into implicit structured information. In our case, the information of interest in the clinical texts included medical history, information about possible travels to third countries, and health habits.

For the data mining tasks, biomedical language models are trained and published as a basis for the development of applications in Clinical Natural Language Processing (NLP). This implies that we generate and publish biomedical language models in Spanish using: a) large biomedical corpora totaling 1.1B words obtained from web downloads, scientific publications, patents in the field, etc., and b) a corpus of electronic clinical histories of 95M words.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/23

As can be seen, this working methodology was published in May 2022 in the article “Pretrained Biomedical Language Models for Clinical NLP in Spanish in Proceedings of the 21st Workshop on Biomedical Language Processing (pp. 193-199 <https://aclanthology.org/2022.bionlp-1.19/>). According to the report in the article, for each biomedical resource, we applied a cleaning tool with customized operations designed to read data in different formats, split them into sentences, detect the language, eliminate malformed and repeated sentences, etc. In contrast, we did not apply any pre-processing to the clinical histories, and they were added as is to the training corpus because such pre-processing is not necessary. This is explained by the different nature of the data: in the first case, referring to section (a), the data has diverse formats (HTML, PDF, RTF) and the text needs to be extracted, while in the second case, referring to section (b) “clinical histories”; the text is already in plain format (txt) and no extraction or pre-processing is required.

The non-manipulation of clinical texts explains why occasional personal data was not detected in the texts, as it was not necessary to access, view, and analyze the data one by one. In accordance with what was indicated earlier, for the clinical histories, since they came in format (txt), it was not necessary to open that format and pre-processing was not required.

In summary, the language modeling tasks did not require exhaustive analysis and manipulation of the texts, as they were added to the training dataset. Thus, the researchers at BSC-CNS did not need to open, access, or process the texts to carry out the data mining work related to the clinical histories; which, in any case, should have already been anonymized at source by the hospital entities, which were responsible for the data. The clinical histories, coming in format (txt), were added to the training corpus without pre-processing.

This is why, according to the evidence provided by the AEPD, it is only possible that such personal data appeared when executing “ad hoc” search commands; that is, searches with patterns specifically designed to locate potential personal data. We do not know the purpose of this search since accessing this personal data is not required to perform the functions and tasks assigned at BSC-CNS, as previously noted. In other words, to carry out language modeling tasks, access to personal data is not necessary.

BSC-CNS continues to describe the obligations and the working methodology employed by BSC-CNS within the framework of these agreements:

Development of predictive models

Predictive models in health are trained with data corresponding to large patient cohorts to help identify patients at risk of developing certain conditions. In our case, the objective was the early prediction of

the risk of death and the need for assisted ventilation.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
10/23

For the generation of predictive models from structured data, we only have data from Hospital 12 de Octubre. Due to internal technical reasons at the hospital, the Hospital Clinic of Barcelona was unable to perform the equivalent export, and we never had access to their data. The objective was to increase the data that the entity HM Hospitales had made available to the scientific community for research on COVID-19 (<https://www.hmhopitales.com/coronavirus/covid-data-save-lives>). The data from HM Hospitales included information on diagnoses, treatments, admissions, ICU stays, diagnostic tests, laboratory results, discharge or death, among other records. With the opening of this dataset, HM Hospitales aimed to provide the medical and scientific community with clinical data to obtain predictive models of evolution, epidemiological models, and information on the response to various treatments applied.

According to the article published in December 2022, which outlines the methodology for developing predictive models from these agreements, “Predicting the evolution of COVID-19 mortality risk: A Recurrent Neural Network approach. Computer Methods and Programs in Biomedicine Update, 3, 100089” (<https://doi.org/10.1016/j.cmpbup.2022.100089>), the goal was to develop a model based on Recurrent Neural Networks to predict the outcomes of patients admitted with COVID-19. Two datasets were used: those from HM Hospitales and H12O, respectively. In both cases, the data contained static variables that remain constant throughout the admissions, such as sex or age, and dynamic variables that are measured at different times during the hospital stay, such as medication, laboratory tests, and vital signs. The data did not contain personal data, and in no case did the experiment deal with data from free-text fields that could incidentally contain any undesirable personal data in these fields, as stated, this data is neither precise nor necessary for carrying out these projects. The fields used for the work are duly reported in the cited article and were the only ones to be considered by our researchers according to the functions assigned in the agreements.

Again, the evidence provided regarding possible observations of undesirable personal data is the result of executing “ad hoc” search commands on the dataset, as observed in the document submitted as evidence in the complaint filed. If such personal data—of a residual and incidental nature—has appeared, it is because such a search was intentionally provoked. Thus, the possibility of finding unforeseen undesirable personal data is practically nil due to the small number of records with free-text fields; especially considering that, to develop predictive models, only the characteristics and evolution of the disease are needed, and in no case, personal data.

It should be reiterated that the researchers identified in the projects of these agreements did not inform the technical managers of the BSC-CNS.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
11/23

existence of personal data in the documentation. As already indicated in the previous information request, if a researcher from BSC-CNS had detected the existence of personal data, they were obliged to communicate this circumstance to the technical managers of BSC-CNS so that BSC-CNS could adopt the necessary technical and legal measures and notify the Data Controller. In the event that the researcher did not make such notification, this researcher would be in breach of their employment contract, the user policy of BSC-CNS, and their obligation to act in good faith and with the due professional diligence required of all employees in the processing of personal data.

Finally, it should be emphasized that until the submission of this documentation attached to your complaint, we were unaware of the existence of this personal data since no user reported its existence. Under no circumstances did BSC-CNS users access or process personal data to carry out

the functions assigned in the agreements, as it was not necessary to access such data to perform data mining activities or to develop predictive models. And in the event that there had been any user who found that personal data, it would have been due to their bad faith and motivation to deliberately and specifically seek it out with the sole purpose of harming this entity.

It should be noted that this documentation containing personal data was not indexed nor was any processing carried out on it since its existence was unknown. However, despite this, this entity applied all security measures to ensure the proper use of this information, as evidenced to this Agency with the documentation provided in this writing and previous ones.

In summary and to conclude, we wish to state the following: a) that BSC-CNS complied with the obligations set forth in the agreement (to carry out data mining tasks and develop predictive models), b) that BSC-CNS was not responsible for carrying out the anonymization, c) that the hospitals were required to send the data duly anonymized at source in accordance with their obligations in the agreements, and d) that the COVID projects of the agreements had the corresponding approval from the Clinical Research Ethics Committee, which evaluated the anonymization of personal data.

In the third request made by this inspection, BSC-CNS was asked to provide the data processing agreement with IBM in case this entity had to process personal data under this contract. In response BSC-CNS 3, the clause on the processing of personal data from the reference document is provided, and it is stated that:

In this regard, the data processing agreement is not provided because there was no processing of personal data. IBM personnel do not have access to the data stored in the GPFS system, as they do not need it for the contracted maintenance tasks, and therefore it was not necessary to include it in the contract.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
12/23

Continuing with the security measures, BSC-CNS states that:

The security policy of BSC-CNS aims to guarantee security at its highest level by incorporating those elements that allow for the execution of the tasks received without compromising security and confidentiality. Therefore, it is based on the fact that only certain profiles within the operations department can hold the position of administrators to grant or modify user permissions. (...)

The security measures implemented in the projects are analyzed specifically on a case-by-case basis, from the perspective of information security and confidentiality of the information involved. In this case, due to the characteristics of the investigations and tasks to be carried out in these projects, users must be authorized and are granted access, reading, and modification permissions, which allow for the downloading and processing of that information in order to work on the Projects. Access to project information is only permitted if one is duly and expressly authorized. Additionally, users who access the information stored on those servers must handle, safeguard, and store it in accordance with the obligations detailed in the BSC-CNS User Responsibilities Policy and must also sign a declaration of compliance with those obligations before accessing the information stored on the servers. Document five accompanies this policy of responsibilities.

At this point, it is necessary to emphasize regarding the protection of personal data that BSC-CNS data users do not process or view personal data in these projects. In the hypothetical case that there is a possible re-identification, it must be communicated as soon as possible to the Project manager, who will immediately notify the persons responsible for data protection within the organization. The purpose of this communication would be to analyze the terms of the signed agreements and to preventively halt the processing of data until the verification of the detected error that led the data processor to incorporate those non-anonymized data, and the adjustment, if applicable, of the necessary legal and technical measures to continue with the execution of the project.

On the other hand, BSC-CNS employees are informed of the compliance rules they must adhere to in data processing, the data protection regulations, and the aspects that affect them as data users on behalf of BSC-CNS upon signing the employment contract. Document number six is attached, which

contains the compliance clause in the employment contract regarding these matters.

Regarding the adaptation and adoption of the National Security Scheme (ENS), it should be noted that BSC-CNS is currently immersed in this procedure. To this end, BSC-CNS has contracted through Rediris the specialized consultancies "Procesia" and "Inycom" for the provision of this service, whose objective is to guarantee adequate

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/23

adaptation to the requirements of the ENS. Therefore, Document FIVE has been attached, which establishes the rules for the use of all information systems, taking into account that the expected date for the completion and implementation of the ENS will be at the end of 2023.

It is also noted that both the Data Protection Officer and an external consultancy specialized in data protection regulations, SEGURDADES, S.L., have participated in the review and analysis of these agreements in order to verify compliance with this data protection regulation and to ensure adherence to the required regulatory principles.

Request to Hospital Clinic de Barcelona (HCB):

In its response, HCB informs that:

The collaboration carried out between the Hospital and the BSC-CNS is contextualized by the development of the research project "Development of predictive models to support clinical decision-making in the field of COVID," (hereinafter, the "Project") which has received a favorable opinion for approval from the Ethics and Clinical Research Committee of HCB, with code HCB/2020/0824, which is attached as Document No. 1.

This collaboration was also regulated between both parties through the Collaboration Agreement between the Barcelona Supercomputing Center – National Supercomputing Center and HCB, dated May 29, 2020, which includes as Annex I the Personal Data Processing Contract. This Agreement is attached to this document as Document No. 2.

The Project protocol, added to this document as Document No. 3, describes in detail the objective and design of the Project, as well as the processes for data preparation and evaluation. A thorough analysis of the method for extracting this data and transferring it to achieve the Project's objective is conducted. It details the different research teams that will have access to the data, the permissions and assigned functions, as well as including a particularly robust anonymization process designed based on:

- Language Technology Promotion Plan, May 2019, from the Government of Spain, attached as Document No. 4
- Guidelines for annotating protected health information from October 2018 from the Government of Spain, attached as Document No. 5
- Anonymization Protocol for Reports for the anonymized COVID-19 Corpus HCB-BSC from July 2022, being a joint working document for the clinical review and validation phase of the anonymization, attached as Document No. 6
- Addenda to the Meddocan Guidelines for HCB anonymization, with concepts identified by clinicians from HCB and added to the consulted guidelines, attached as Document No. 7

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/23

The protocol of the referenced Project also describes, in its section 9.3, the analysis of the detection of risks related to the possible identification of patients at the different stages of data processing, identifying the containment measures for them, an analysis conducted by the research team of the Project.

From the various meetings held with the Director of Medical Informatics, the Principal Investigator of the Project has prepared the attached report as Document No. 8 titled "Management of documentary information between the Hospital Clínic de Barcelona ("HCB") and the Barcelona Supercomputing Center ("BSC") for the development of the Research project on COVID19 articulated by the collaboration agreement between the BSC and the Hospital Clínic signed on May 29, 2020, titled "Development of predictive models for supporting clinical decision-making in the field of COVID19" ("COVID19 Project") (hereinafter, the "Report"). This report details the type of data analysis involved in the Project, the method of transmission of the data, and the methods of anonymization and pseudonymization followed, including screenshots of the processes, as well as determinations of the circuits and functions of each party.

In the context of the Project, the BSC-CNS provides a service to the HCB for risk analysis of re-identification and complete anonymization of the data to be processed in the Project, based on the Data Processing Agreement formalized on May 29, 2020. The Report thoroughly outlines the method of data transmission, the team authorized to access it, as well as the type of information required, the processing using PLN technology provided by the BSC-CNS, and the result of the data once the service in question is completed. The complete information of the data is stored in the HCB's care management system, to which only HCB professionals have access through a nominal user system, personal secret access key that is non-transferable and self-managed, and the corresponding access permissions within the framework of the necessary actions to achieve the objectives of the Project. Therefore, no personnel from the BSC-CNS have a user account to access the indicated care management system, with the management of user authorization for the Hospital's care management system being carried out by Medical Informatics in accordance with a standardized procedure for registration, authorization, and management of the user's digital identity, in accordance with the document Procediment SAP Assistencial Externs v14, attached as Document No. 9.

Regarding the Reports from the Data Protection Officer in relation to these treatments, HCB informs: "In the year 2020, when the Project was approved by the Ethics and Clinical Research Committee of the HCB, it included, among others, a member with sufficient expertise in the knowledge of Regulation (EU) 2016/679, delegated by the Data Protection Officer, in accordance with the seventeenth additional provision 2h) of Organic Law 3/2018, of December 5, on Personal Data Protection and guarantee of digital rights. Thus, participation was made and all evaluations carried out by the Committee regarding the analysis of research projects involving the processing of personal data were taken into account."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
15/23

for which the Hospital is responsible, taking into account in the project analysis its intervention and assessment in the collegial deliberation.

Request to the

INSTITUTE OF HEALTH RESEARCH ILLES BALEARS

(IdIsBa)

A response is received as follows:

- First of all, it is necessary to inform that the object of this collaboration has, at no time, sent personal data to the Barcelona Supercomputing Center Consortium – National Supercomputing Center, hereinafter BSC-CNS, having sent data that is anonymized.
- The need to send anonymized data is detailed in the Agreements signed between BSC-CNS, IDISBA, and the university hospital. (...)
- Due to the aforementioned agreements, information from approximately 1,000 discharge reports has been provided, all of which are duly anonymized.
- Since anonymized data will be processed, the treatment activities to be carried out do not need to

comply with Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, (hereinafter, "GDPR") and Organic Law 3/2018, of December 5, on Personal Data Protection and guarantee of digital rights.

- It is due to the circumstance of not communicating personal data, combined with the fact that in no case was the treatment of data to be anonymized massive, that it was not considered necessary to prepare a privacy impact assessment in accordance with the provisions of Article 35.4 and always from the position of the assignee of anonymized information.

- In the attached document, a descriptive document is provided with the processes of anonymization of reports and records extracted from the electronic medical history, as well as the process of sending the data to the entity Barcelona Supercomputing Center Consortium.

The anonymization process is described as follows:

1.- Selection process of reports and anonymization: After selecting the documents with the required characteristics through a database query, they are extracted in XML format. In the database, only the content of the report is archived and not its header, which contains sensitive data that allows for the identification of the patient. The reports generated for printing or for publication in PDF merge the body of the report (XML file) with a header that is constructed by extracting the patient's identification data and the episode. Therefore, it is possible to extract reports in XML format that do not contain any identification data or identification number that allows it to be related to the patient to whom it belongs. This set of anonymized documents was manually reviewed for two purposes: to verify that they corresponded to the type of information required for the research project and to ensure that they did not include identifying data of the patient in accordance with what was required by Data Protection at that time. The files had random numbering as the identification of the case was not required for the research.

2.- Information sending process: the set of reports was included in a folder that was compressed and encrypted and uploaded to the platform enabled for such use by the ictusnet working group for subsequent use.

Request to the

ANDALUSIAN PUBLIC FOUNDATION FOR HEALTH RESEARCH MANAGEMENT OF SEVILLE (FISEVI):

On January 9, 2023, a request for information was made through electronic notification delivered the following day. This request was reiterated on February 28, 2023, through electronic notification delivered on March 6, 2023. No response has been obtained to the requests, although, as clarified by BSC-CNS, despite the initial signing of the agreement, FISEVI did not send data to BSC-CNS. HCB kept FISEVI informed of its progress with the common data model, but in no case did BSC-CNS receive data from Hospital FISEVI.

Request to the

HOSPITAL UNIVERSITARIO DOCE DE OCTUBRE

(H12O):

The following information is received:

This Data Protection Delegated Committee (hereinafter CDPD), in its capacity as interlocutor of the Ministry of Health with this Agency, in accordance with the provisions of Article 37.2 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (LOPDGDD), appears and formulates in due time and form the following considerations regarding the request:

1. Detailed description with supporting documentation (screenshots, documents, protocols...) of the process of sending the data to BSC-CNS.

"The sending of the data was carried out through an SFTP access provided to the technical team of BSC for the reception of the data." This is stated in the document that has been sent to us by H12O, as noted in the document "Data Pseudonymization Process for COVID-19 Research," which is attached as Annex 1.

(...)

Additionally, we attach as Annex 2 the document from the management of the data controller, H12O,

by virtue of which (i) they inform us of the facts related to the request that was sent to them by you and that we now respond to, and (ii) provide the documentation that from this Delegation we supplied to them.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
17/23

2. Description and evidence of the anonymization process or, if applicable, pseudonymization of the health data provided to BSC-CNS.

In the aforementioned Annex 1, attached, the pseudonymization process of the data provided to BSC-CNS for COVID-19 research is established. We consider the contents of this annex to be reproduced herein.

Additionally, the document titled “Modelo de datos-COVID19” is attached, which describes the information model established to facilitate the pseudonymized data, along with the description of the fields contained in the various tables designed for the referenced project as Annex 3.

3. Risk analysis and impact assessments carried out in connection with these treatments and description of the methodology used for this purpose.

The project was submitted for evaluation to the Ethics Committee of the Center, following internal procedures, and in accordance with the provisions of DA 17^a letter h) of the LOPDGDD, which analyzed it on 14/01/2021, obtaining a result as transcribed: “Conclusion: Therefore, it considers that evaluation is not appropriate.” This opinion is attached as Annex 4.

Additionally, regarding the methodologies employed by the Health Department of the Community of Madrid and by all responsible parties that comprise it:

- for risk management and analysis of information systems, MAGERIT using the PILAR tool.
- for data protection impact assessments, the methodology of the AEPD itself is followed, using various tools, some specifically developed for the CSCM.

4. Reports from the Data Protection Officer in relation to these treatments.

H12O, as the data controller, did not obtain a specific and/or concrete report from this CDPD regarding participation in the project, although it is noted that it acted diligently in having signed the corresponding agreement that established the measures to be adopted for its execution, and requested the mandatory report from CEIM.

As it has received the request from the AEPD that we are now responding to, it has approached this Delegation, informing us of all this, as well as the attached Annex 2.

The pseudonymization process of data for COVID-19 research is described as follows:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

18/23

Introduction

This document describes the pseudonymization process of COVID-19 data to be used for purposes additional to the individual patient care.

Patient Data

The Electronic Clinical History (ECH) of the Hospital Universitario 12 de Octubre has different personal identifiers at the patient level (NHC, CIPA, DNI, name and surname, address, etc.). Therefore, in the various data extraction processes for secondary use (research, model training, evaluation, etc.), a pseudonymization process of the information is carried out, eliminating all sensitive data and linking each record of the same patient to an artificial and unique code, not linked to the individual, “ID_SEUDO.”

This correspondence between pseudonymized codes and sensitive codes is carried out in the Hospital's infrastructure within the ECH database, with all the security mechanisms that this implies,

and this information is not accessible to the data consumers of the use case that demands them.

Below is a screenshot of this correspondence table in the ECH, omitting sensitive data:

Correspondence table for the pseudonymization of the ECH

Likewise, in the document "ModeloDatos-COVID-19," the structure and content of the exported files can be seen, all of them with the unique patient identifier "ID_SEUDO," and without any other identifying or personal data of the patient.

For the sending of unstructured data, an automated process was implemented that extracts the body of the report (in this case, the use applies to Radiology) without any identifying metadata of the patient or the professional. Identification is done by assigning to each text file an internal code of the information system where they were generated as the name.

Professional Data

No personal data of professionals is extracted in the data collection processes for secondary use. In specific projects that require it (this is not the case for the project with BSC), each record is identified with an internal code indicating the user who created it in the system's database.

Sending Data

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

19/23

The transmission of the data was carried out through a (...) provided to the technical team of the BSC for the reception of the data.

****Request to the complainant****

On February 16, 2023, the complainant was requested to provide documentation evidencing the reported facts, as the complaint included links (**LINK.1 and **LINK.2) that could not be accessed.

On February 21, 2023, the complainant complied with the request, providing five pages that included some personal data that do not appear to belong to the patients themselves, but rather to their relatives. Additionally, data from the doctors who attend to them is included.

The complainant also submitted a document containing just over 70MB of information, where it is confirmed that the information is anonymized. Numerous searches have been conducted in this document, and within a vast volume of anonymized information, data from medical personnel and some isolated personal data not detected by the anonymization processes executed automatically for text fields and medical reports have been located.

Since the information provided was deemed insufficient, the request for documentation was reiterated on March 14, 2023.

On March 19, 2023, the complainant requested an extension of the deadline, which was granted through electronic notification delivered on March 21, 2023, without compliance with the request.

****LEGAL GROUNDS****

I

****Competence****

In accordance with the functions conferred to each supervisory authority by Article 57.1 a), f), and h) of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR) and as provided in Articles 47 and 48.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to resolve these investigative proceedings.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development, and, to the extent that they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

****Security of Processing****

C/ Jorge Juan, 6

www.aepd.es

20/23

Article 32 of the GDPR stipulates the following:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data promptly in the event of a physical or technical incident;
- d) a process for regularly testing, assessing, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data only processes such data on instructions from the controller, unless required to do so by Union or Member State law."

III

****Principles Relating to Processing****

Letter f) of Article 5.1 of the GDPR states:

"1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of appropriate technical or organizational measures ('integrity and confidentiality')."

IV

****Reported and Investigated Facts****

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/23

The reported facts specify that BSC-CNS has access to personal data for which various hospitals would be responsible for processing. The accessed data would include: ID number, phone numbers, professional registration number, complete structured and unstructured medical history; there being no adequate access control to such data, allowing any employee (including interns) to access and download it.

The investigative actions have focused on analyzing the data processing that BSC-CNS performs as a data processor. The data processing carried out by the Hospitals/Foundations that are responsible for processing has not been investigated. The latter have been requested to provide a description and evidence of the anonymization/pseudonymization processes, as well as the transfers of anonymized or pseudonymized data to BSC-CNS within the framework of the agreements signed between the

controllers (hospitals/foundations) and the processor (BSC-CNS).

The investigative actions have primarily aimed to analyze whether the processing carried out by BSC-CNS allows for complete identification of the data subjects, as well as to examine the security measures implemented by BSC-CNS to control the access of research personnel to such data. In the investigative actions, it has not been possible to demonstrate that it is feasible, with the activity carried out by BSC-CNS as a data processor, to identify the individuals affected by the processing. After analyzing the documentation provided regarding the anonymization/pseudonymization processes, the submitted screenshots confirm a first layer of pseudonymization of demographic and identifying data; in this first layer, the data from the header fields of the document are removed, but the text fields where comments have been entered by the doctors remain. In these fields, there may also be data that allows for the identification of the patient, but Natural Language Processing (NLP) algorithms available at BSC are used for their obfuscation, and a screenshot evidencing the application of this technology is provided.

Regarding the submission of data from the controllers to BSC-CNS, from the evidence submitted by the hospitals/foundations (responsible for processing), it can be concluded that they had established and implemented anonymization/pseudonymization processes, and in this case, both in the allegations made by the controllers and by the data processor (BSC-CNS), it is stated that these procedures were followed.

Regarding the data processing carried out by BSC-CNS, there are solid indications that allow us to conclude that no processing has been done that would allow for the identification of affected data subjects. The evidence provided by the complainant regarding possible observations of undesirable personal data is the result of executing "ad hoc" search commands on the dataset, but it is not demonstrated that this data was processed manually; rather, the information is directly input into the algorithms and machine learning systems.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/23

No manipulation of clinical texts explains that no occasional personal data would be detected in the texts, as it was not necessary to access, view, and analyze the data one by one. The objective of BSC-CNS, as stated, was to receive anonymized data at source since it was not necessary to identify or process personal data to perform the tasks of the agreement. BSC-CNS received the anonymized clinical texts to which BSC-CNS applied natural language processing techniques to enable the automatic extraction and normalization of clinical concepts.

Despite the fact that the information processed by BSC-CNS (and sent by the hospitals) was anonymized, the following accredited security measures were in place:

- Access to information by workers through a permission and authorization management system based on groups and access lists.
- Workers were not allowed to store information on their professional or personal computers, which was covered by the usage and security policy that they had to accept. It has been established that of the seven workers in the BSC-CNS research group, three of them manually signed the usage policy and responsible declaration, while the rest accepted it through a checkbox that they had to explicitly mark, indicating that they had read the usage policy and responsible declaration.
- The use of personal computers was authorized in exceptional and duly justified cases due to the pandemic situation at the time.
- (...).

V

Conclusion

Therefore, based on the information indicated in the previous paragraphs, no evidence has been found to support the existence of an infringement within the jurisdiction of the Spanish Agency for Data Protection.

In accordance with the above, the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO FILE the present proceedings.

SECOND: TO NOTIFY this resolution to the BARCELONA SUPERCOMPUTING CENTER - NATIONAL SUPERCOMPUTING CENTER CONSORTIUM.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative process as provided by Article 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, and in accordance with the provisions of Articles 112 and 123 of the aforementioned Law 39/2015, of October 1, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

940-020323

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es